

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)

Assessment Tool Weightage: 20%

QUESTIONS: 5 TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I Challa Priyadarshini(192311118) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Ch Priyadarshini

Question 1:

Executive Summary

This report analyzes five practical enterprise security problems involving secure network communication, cryptographic key management, secure email, spam and phishing detection, and S/MIME certificate security. Each case is treated as an industry problem rather than only a theoretical protocol question. The analysis identifies the security requirements, compares available mechanisms, proposes an implementable architecture, and evaluates operational and performance considerations.

For branch-to-branch connectivity, ESP tunnel mode is recommended as the normal IPSec baseline because it can provide confidentiality and integrity/authentication while protecting the original IP packet. IKEv2 should automate Security Association establishment and rekeying so that large numbers of VPN tunnels can be managed consistently. For enterprise secure email, S/MIME is generally the stronger choice where centralized identity, certificate authorities, managed mail clients, and compliance processes already exist. Spam and phishing defense should combine authentication results, header analysis, content signals, reputation, and adaptive classification. Finally, S/MIME certificate security requires disciplined lifecycle management, trusted validation, protected private keys, and user awareness.

Key Recommendations at a Glance

Case	Primary Recommendation	Main Benefit
1. IPSec branch VPN	ESP tunnel mode + authenticated encryption	Confidentiality and integrity
2. IPSec key management	IKEv2 + automated SA lifecycle	Scalable and reliable key exchange
3. Secure email	S/MIME for centrally managed enterprise	Usability and centralized trust
4. Spam/phishing	Layered header + content + reputation/ML	Higher detection with controlled false positives
5. S/MIME certificates	Centralized PKI lifecycle + secure key storage	Reliable trust and certificate validation

1. IPSec Security Between Multinational Branch Offices

Problem context: A multinational enterprise has offices connected through the public Internet. Traffic may include financial records, customer information, credentials, internal applications, voice, and video. The enterprise therefore needs confidentiality, integrity, authentication, replay protection, and reliable operation without excessive overhead.

A. Identify Which Traffic Requires AH, ESP, or Both

Authentication Header (AH) provides integrity and authentication for protected portions of an IP packet, but it does not encrypt the payload. Encapsulating Security Payload (ESP) can provide confidentiality and, when configured for authenticated encryption or with an integrity mechanism,

integrity and authentication. Consequently, ESP is normally the preferred protocol for modern site-to-site VPNs.

Traffic	Recommended Protection	Reason
Financial records	ESP	Sensitive data requires confidentiality and integrity.
Customer/employee data	ESP	Protects privacy and prevents modification.
Credentials/tokens	ESP	Prevents interception of sensitive authentication data.
Internal applications	ESP	Provides complete protection across public networks.
Voice/video	ESP	Protects content while allowing optimized performance.
Integrity-only special traffic	AH	Useful when confidentiality is not required.
Exceptional layered policy	ESP + AH	Only when an explicit independent integrity requirement exists.

AH should not normally be combined with ESP simply because both are available. Such a configuration increases packet size and processing and may create interoperability problems. In particular, AH authenticates selected IP-header information, so network address translation and other header changes can conflict with its integrity calculation. ESP is therefore the practical default for Internet-facing branch VPNs.

B. Design Packet Flow and Select IPSec Mode

For gateway-to-gateway branch communication, tunnel mode is the appropriate choice. The sending gateway receives the original packet, applies ESP protection to the original packet, and adds a new outer IP header. The public Internet routes the packet using the outer addresses. The destination gateway validates and decrypts the ESP packet, removes the tunnel encapsulation, and forwards the original packet to the destination host.

Conceptual packet flow:

Branch A Host → IPSec Gateway A → ESP Tunnel across Public Internet → IPSec Gateway B → Branch B Host

In tunnel mode, the original IP header and payload are protected inside the tunnel. Transport mode, by contrast, retains the original IP header and protects the upper-layer payload. Transport mode is more suitable for host-to-host IPSec and generally has less overhead, while tunnel mode is ideal for site-to-site VPNs.

C. Justify Protocol Selection for Different Data Types

Financial transactions and confidential documents require both confidentiality and integrity, so ESP with authenticated encryption is appropriate. Customer records and employee credentials should receive the same strong protection because exposure can result in privacy violations and fraud. Voice

and video should also use ESP, but the deployment should consider latency, packet size, QoS, and hardware acceleration. Integrity-only traffic could use AH, but organizations often standardize on ESP to simplify policy and operations.

D. Performance vs Security Trade-offs

Encryption and authentication consume processing resources. ESP also adds headers and trailers, increasing packet size and potentially reducing the effective MTU. Tunnel mode adds another IP header. These costs can be reduced with hardware cryptographic acceleration, appropriate MTU settings, efficient authenticated encryption, and QoS.

AH avoids payload encryption but does not provide confidentiality and can be less compatible with NAT. Therefore, the security gain from using AH alone is insufficient for sensitive branch traffic. The recommended enterprise balance is ESP tunnel mode using a modern authenticated-encryption algorithm such as AES-GCM, with strong gateway authentication and automated key management.

Q1 Conclusion

The enterprise should deploy site-to-site IPsec using ESP tunnel mode as the default. AH should be reserved for special integrity-only or policy-driven cases. This provides strong confidentiality and integrity while keeping the architecture operationally manageable.

2. Automated IPsec Security Association and Key Management

Problem context: The organization experiences expired and mismatched keys. Manual key configuration does not scale and can cause tunnel outages. The solution should automate authentication, cryptographic negotiation, SA creation, rekeying, revocation, monitoring, and recovery.

A. Analyze Current SA Lifecycle Issues

- Manually configured keys can become inconsistent across peers.
- SA lifetimes may differ, causing one peer to delete an SA while the other still expects it.
- Cryptographic proposals may not match, preventing negotiation.
- Failed rekeying can cause outages when old SAs expire.
- Clock differences can affect certificate validity and security decisions.
- Stale SAs can remain after topology or policy changes.
- Compromised credentials may not be revoked quickly.
- Lack of centralized monitoring makes failures difficult to diagnose.

These problems are symptoms of an unmanaged SA lifecycle. In a large enterprise, every branch gateway should follow a common policy and should establish fresh keying material automatically rather than relying on administrators to copy keys manually.

B. Design an Automated IKE-Based Mechanism

IKEv2 should be used as the control-plane mechanism for IPsec. It authenticates peers, negotiates cryptographic algorithms, establishes secure keying material, and creates Child SAs for data traffic. Certificates can be used for scalable gateway authentication where an enterprise PKI exists.

High-level workflow:

1. Gateway A initiates IKEv2.
2. Gateway B responds.
3. Both peers authenticate and negotiate cryptographic parameters.
4. The IKE security association is established.
5. Child SAs are created for

ESP traffic. 6. Data is transmitted through the IPSec tunnel. 7. Rekeying occurs automatically before SA expiry. 8. Old SAs are retired after the transition.

C. Strategy for Key Renewal and Revocation

Rekeying should occur before expiration rather than waiting for a tunnel to fail. The new SA should be established and tested while the existing SA is still available. After traffic moves to the new SA, the old SA can be deleted according to policy.

For certificate-based authentication, the enterprise should monitor certificate expiry, maintain approved revocation mechanisms, and immediately revoke compromised certificates or credentials. Central logging should record authentication failures, rekey failures, and unusual negotiations.

D. Scalability and Fault Tolerance

IKEv2 scales significantly better than manually distributed keys because peers negotiate and refresh keying material automatically. Centralized policy and certificate management also reduces configuration drift. For fault tolerance, deploy redundant VPN gateways, synchronized configurations, and multiple network paths where business requirements justify them.

Monitoring should provide dashboards and alerts for tunnel availability, IKE failures, Child SA state, certificate expiry, rekey errors, and abnormal authentication attempts. Automated recovery should establish new SAs instead of depending on stale state.

Q2 Conclusion

An IKEv2-based architecture with automated SA creation, renewal, revocation, centralized policy, monitoring, and redundant gateways solves the key-management problem while improving enterprise scalability and availability.

3. Secure Email: PGP versus S/MIME

Problem context: A financial services organization needs secure email for sensitive transactions. The solution must support confidentiality, digital signatures, identity assurance, centralized administration, and regulatory requirements.

A. Compare PGP and S/MIME in Real-World Deployment

Factor	PGP	S/MIME
Trust model	Decentralized/web of trust	CA-based X.509 PKI
Enterprise administration	More user-driven	Highly centralized
Email-client integration	Varies by product	Strong in managed enterprise clients
Scalability	Good with disciplined tooling, but more complex trust administration	Strong for centrally managed organizations
User experience	Can require more key/trust decisions	Usually simpler for managed users
External/decentralized use	Strong fit	Strong when partners support PKI

Compliance/central governance	Depends on implementation	Often easier to integrate with enterprise PKI
-------------------------------	---------------------------	---

PGP is flexible and can work well where users or communities control their own trust relationships. S/MIME is based on X.509 certificates and a certificate authority hierarchy, making it more compatible with centralized enterprise identity and certificate management.

B. Key Management and Trust Models

PGP commonly uses a web-of-trust model. Users verify public keys and may sign other users' keys. This offers flexibility but can become difficult to govern when thousands of employees and external partners are involved.

S/MIME uses certificates issued by trusted certificate authorities. A recipient validates the certificate chain, identity, validity dates, key usage, and revocation status. The organization can define certificate policies and automate issuance and renewal.

Both approaches depend on strong private-key protection. A stolen private key can compromise encrypted information or undermine digital signatures, so endpoint security and key storage are essential.

C. Recommendation

S/MIME is recommended for the financial enterprise when managed mail clients, directory services, enterprise PKI, and centralized identity systems are available. It offers a predictable trust model, centralized lifecycle management, and good integration with enterprise email platforms.

PGP remains a viable option for selected external partners, specialist users, or environments where decentralized trust is a deliberate requirement. A hybrid policy may therefore be appropriate, but S/MIME should be the standard for the internal enterprise population.

D. High-Level Implementation Workflow

Establish a certificate policy → select a trusted CA → enroll authorized users → protect private keys → configure managed email clients → publish/exchange public certificates → enable signing and encryption → validate certificates and revocation status → automate renewal → monitor certificate health → train users.

Q3 Conclusion

For a centrally managed financial organization, S/MIME generally provides the best combination of usability, scalability, identity assurance, and enterprise integration.

4. Advanced Spam and Phishing Detection

Problem context: Basic email filtering is no longer sufficient because attackers continuously change wording, domains, sender identities, links, and attachments. A layered detection system should combine header authentication, content analysis, reputation, and adaptive classification.

A. Limitations of Existing Filtering

- Keyword-only rules are easy to evade using misspellings, images, obfuscation, and changing phrases.
- Static sender block lists do not reliably detect newly created malicious infrastructure.
- Simple URL filters may miss short-lived or compromised domains.

- Overly aggressive rules create false positives and can block legitimate business mail.
- Header-only inspection cannot reliably classify every message.
- Attackers increasingly use legitimate services and realistic business language.

B. Email Header Analysis for Spoofing

The detection system should inspect From, Reply-To, Return-Path, Received, Message-ID, Date, and authentication results. The visible From address should be compared with the actual sending infrastructure and reply destination.

SPF checks whether the sending host is authorized for the domain. DKIM verifies a cryptographic signature over selected message content and headers. DMARC connects domain alignment with SPF and/or DKIM and allows a domain owner to publish a policy. These results should be treated as important signals rather than the only decision factor.

Other indicators include unusual Received-header chains, unexpected source networks, suspicious domains, abnormal timestamps, mismatched Reply-To addresses, and sending patterns inconsistent with the organization.

C. Improved Detection Model

A layered architecture should first apply deterministic high-confidence rules. Examples include known malicious domains, failed authentication combined with other suspicious signals, dangerous attachment types, and clear credential-harvesting patterns.

The content layer should analyze subject and body language, URLs, domain age/reputation where available, attachment characteristics, unusual formatting, credential requests, urgency, financial manipulation language, and similarity to previously confirmed phishing campaigns.

For a larger enterprise, these features can be combined in an ML classifier such as logistic regression or a tree-based model. The classifier should output a risk score. Policy can then map scores to allow, quarantine, or reject actions.

D. Effectiveness and False Positive Handling

Evaluation should use precision, recall, false-positive rate, false-negative rate, and detection latency. A test set should contain legitimate business mail, normal newsletters, known spam, and confirmed phishing.

High-confidence threats should be rejected or quarantined. Medium-risk messages should be quarantined for human or automated review. Low-risk messages can be delivered. Users should have a controlled process to report false positives and suspected phishing.

The system should continuously learn from confirmed outcomes and monitor model drift. Allow lists should be narrow and controlled so that attackers cannot exploit broad exceptions.

Q4 Conclusion

A layered detection model is stronger than a simple keyword filter. Combining SPF, DKIM, DMARC, header analysis, content signals, URL and sender reputation, and adaptive classification can improve detection while maintaining acceptable false-positive levels.

5. S/MIME Certificate Security and Trust Validation

Problem context: A security audit found that encrypted email is vulnerable because certificates are not handled correctly. Even strong cryptography cannot provide reliable security if the wrong certificate is trusted, certificates are expired or revoked, or private keys are exposed.

A. Potential Certificate Vulnerabilities

- Expired or not-yet-valid certificates.
- Certificates issued by untrusted or unexpected CAs.
- Incorrect subject/SAN identity or certificates used for the wrong purpose.
- Missing or inappropriate key-usage extensions.
- Revoked certificates that are still accepted.
- Weak or obsolete cryptographic algorithms.
- Private keys stored without adequate protection.
- Users ignoring certificate warnings.
- Failure to renew certificates before expiration.
- Failure to replace certificates after key compromise.

B. Trust Chain and Validation Process

A recipient should build a chain from the sender's certificate through intermediate CAs to a trusted root CA. Every certificate in the chain should be checked for issuer signatures, validity dates, identity, key usage, and revocation status.

The organization should use approved CRL or OCSP mechanisms where applicable. Trust decisions should also comply with internal certificate policy. For digital signatures, the certificate establishes confidence in the signing identity and public key. For encryption, the sender must use a valid public certificate for the intended recipient.

Certificate validation should occur automatically where possible. A user should not be expected to manually inspect every technical certificate field.

C. Secure Certificate Storage and Management

Private keys should be protected using operating-system credential stores or hardware-backed key protection where available. Private keys should never be placed in plaintext files or transmitted by email.

Centralized certificate lifecycle management should track owner, purpose, issue date, expiry date, renewal status, and revocation status. Automated renewal should begin well before expiration. Compromised certificates should be revoked promptly and replacement keys should be generated under controlled procedures.

The organization should maintain audit records for certificate issuance, renewal, revocation, and administrative changes. Secure backup and recovery procedures should be established without weakening private-key protection.

D. User Awareness and System Configuration

Users should be trained not to ignore certificate warnings. They should know that encryption and digital signatures provide different security properties and that a valid-looking email address is not sufficient evidence of identity.

Enterprise mail clients should be configured with approved trust anchors, secure algorithms, certificate validation, and managed certificate discovery. Security teams should periodically audit endpoint certificate stores, trusted roots, expired certificates, and revocation behavior.

Q5 Conclusion

Secure S/MIME depends on the entire certificate lifecycle, not merely on encryption. Strong PKI governance, protected private keys, automatic renewal, revocation, correct trust-chain validation, secure configuration, and user training are required.

Cross-Case Enterprise Implementation Roadmap

The five cases can be addressed through a coordinated security program rather than isolated controls.

Phase	Key Activities	Expected Outcome
1. Assessment	Inventory VPNs, email systems, certificates, identities, and current filtering rules	Known security baseline
2. Architecture	Standardize ESP/IKEv2, PKI, email security, and detection architecture	Consistent enterprise design
3. Automation	Automate SA rekeying, certificate renewal, monitoring, and alerting	Reduced human error
4. Detection	Deploy header/content/reputation analytics and quarantine workflows	Improved phishing detection
5. Governance	Define policies for algorithms, trust anchors, key storage, revocation, and exceptions	Controlled security lifecycle
6. Testing	Perform failover tests, certificate tests, phishing simulations, and performance tests	Validated resilience
7. Continuous Improvement	Monitor metrics, update rules/models, and review incidents	Adaptive security posture

Final Conclusion

The five industry problems demonstrate that effective cybersecurity requires more than selecting a single protocol. IPSec should use ESP tunnel mode for most branch-to-branch traffic and IKEv2 for automated Security Association and key management. Secure enterprise email should normally use S/MIME where centralized PKI and managed clients are available, while PGP remains useful for decentralized or specialized environments. Spam and phishing protection should combine message

authentication, header analysis, content inspection, reputation, and adaptive classification. Finally, S/MIME certificates must be treated as managed security assets with controlled issuance, protected private keys, trusted validation, renewal, revocation, monitoring, and user education.